



Nagoya Institute of Technology

製造DX時代のOTセキュリティの考え方

名古屋工業大学 産学官金連携機構 ものづくりDX研究所 客員准教授
佐々木 弘志

サイバー攻撃で工場停止からビジネスリスクが拡大する事例が増加

生産停止

サイバー攻撃で被害のアサヒHD、いまだ復旧の目途立たず DX
化で問われる安全対策

2025/10/8 16:13

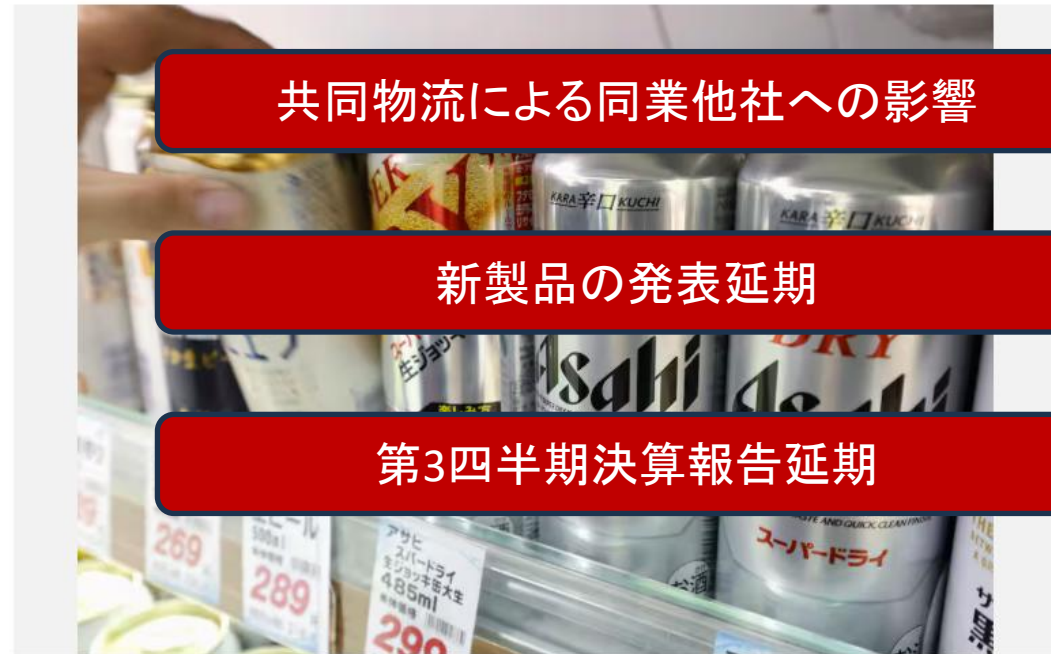


村田 幸子

共同物流による同業他社への影響

新製品の発表延期

第3四半期決算報告延期



店頭に並ぶアサヒビールの「スーパードライ」など=3日午後、横浜市保土ヶ谷区

サイバー攻撃で操業停止のジャガーに3000億円支援提供 英政

売上損失・事故対応費用・評判低下・情報漏洩

国際 | 欧州・ロシア サイバー攻撃

従業員帰休(補償)・サプライチェーン波及

生産再開2度延期による被害拡大

政府からの巨額融資(数千億円)・規制強化

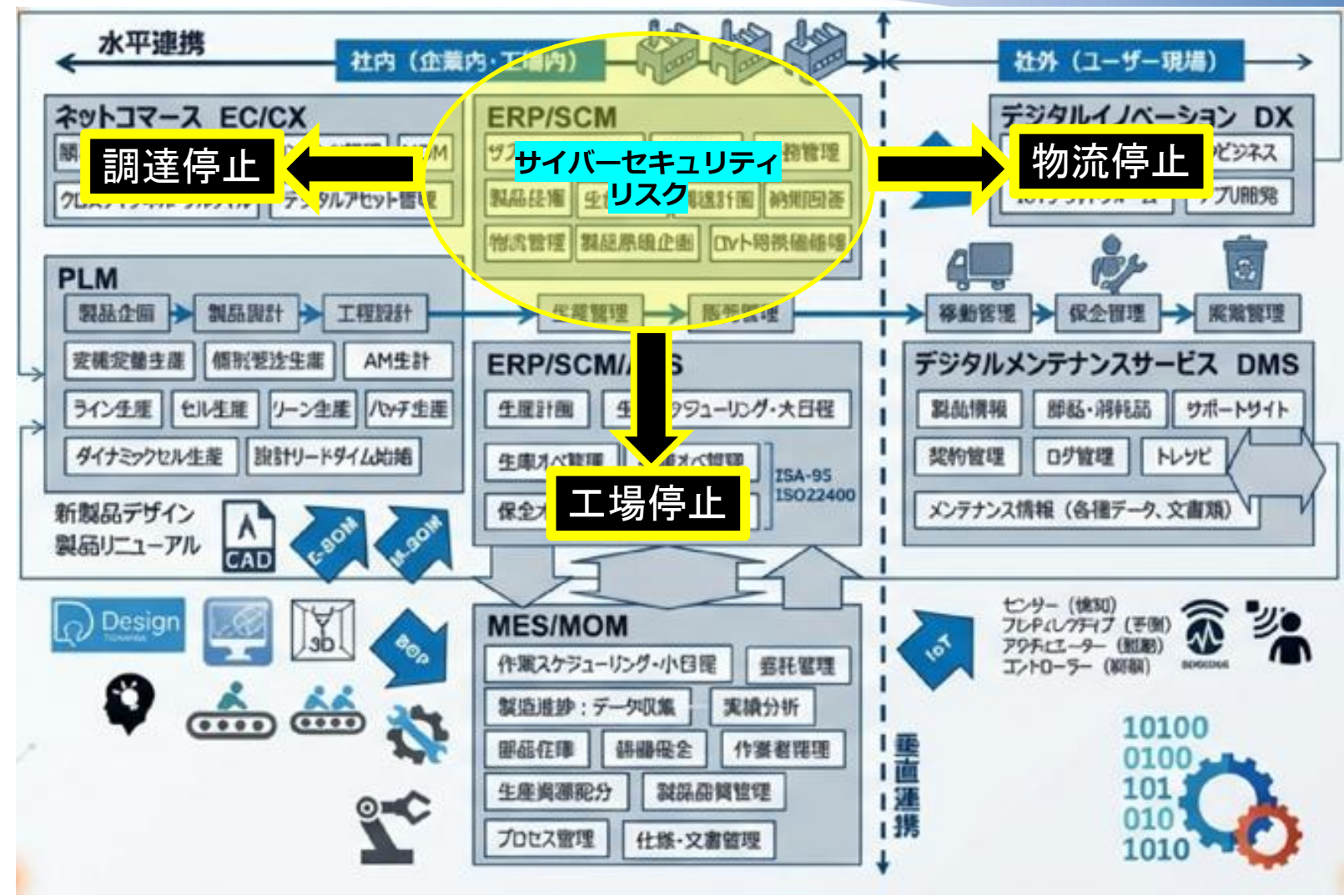


一攻撃を受け操業を一時
ジャガー・ランドローバー
(JLR)に、15億ポンド(約3千億円)の資金繰り
支援を提供すると発表した。民間の金融機関からの
影響が生じているサプラ

JLRは9月初旬、サイバー攻撃を受けシステムを
因調査に伴い24日まで操
が、10月1日まで延長し
た。近く一部の操業を再開する。

英政府によると、JLRと関連企業には計10万人以
上の従業員がいる。(共同)

典型的なDXアーキテクチャに潜在するビジネスリスク



- システムはデジタルでつながるのに各部門はサイロのまま。
(個別最適)
- システム全体を把握している人がいない。
→サイバーリスクが
想定外のビジネスリスクを生む



“DXによるシステム連携”
に組織態勢・文化が
適応できておらず
潜在的なビジネスリスクが拡大



Mission : 「産業サイバーセキュリティの文化を創る」

- ・産業制御システム開発者（14年）
- ・産業制御システムセキュリティのコンサルタント（13年+）

2012年11月～現在

- ・セキュリティベンダーにて産業サイバーセキュリティのビジネス開発
(現：フォーティネットジャパン合同会社 OTビジネス開発部 部長)

2016年5月～2020年12月, 2021年7月～現在:

- ・経済産業省 サイバーセキュリティ課 情報セキュリティ対策専門官(非常勤)

2017年7月～現在:

- ・IPA 産業サイバーセキュリティセンター サイバー技術研究室 専門委員

2022年5月～現在:

- ・名古屋工業大学 産学官金連携機構 ものづくりDX研究所 客員准教授, 博士(工学)

2023年6月～現在:

- ・株式会社 アクセルスペースホールディングス サイバーセキュリティプリンシパル

2024年8月～現在:

- ・JNSA 調査研究部会 OTセキュリティWG リーダー

2025年1月～現在:

- ・Japan Space ISAC 理事

政府委員:

- 工場SWG セキュリティガイドライン検討委員
- 宇宙産業SWG セキュリティガイドライン検討委員



産業サイバーセキュリティセンター（ICSCoE）



OT（制御技術）とIT（情報技術）の知見を結集させた
サイバーセキュリティ対策の中核拠点として発足



人材、技術、ノウハウを結集
社会インフラ・産業基盤のサイバーセキュリティ対策を強化

中核人材育成プログラム

経営層と現場担当者をつなぐ人材を育成する1年間のフルタイムプログラム

 テクノロジー(IT・OT)とビジネス
マネジメント分野を総合的に学習

現場から経営層までの広い視点で組織全体、サプライチェーン、業界全体
を見据えたセキュリティやビジネスに対する理解

 模擬システムを使った
実践的な演習

様々な業界のシステムを想定した模擬システム
自社に近い環境での演習を体験、現場におけるリスクについてより深い理解

 国内外の関係機関との
ネットワーク構築

国内外、業種を超えたトップレベルの人脈とのネットワーキング



文京拠点での集合講義



グループワークでの学び



秋葉原の演習拠点



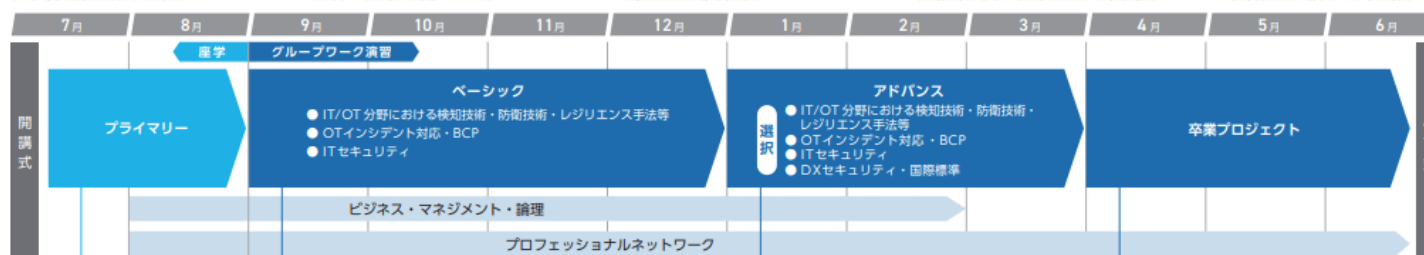
模擬プラントでの実践的な学び



海外派遣演習（フランス）



制御システムの現場を見学（久米島）



IPA



短期プログラム 責任者層～実務者層向けの2～4日間の演習プログラム

※「業界別サイバーレジリエンス強化演習」「制御システム向けサイバーセキュリティ演習」は情報処理安全確保支援士の実践講習として受講可能

アジェンダ

最新のサイバーセキュリティ動向（脅威・政策）

製造DX時代のOTセキュリティの考え方



最新のサイバーセキュリティ動向 (脅威・政策)



米国によるイランに対する軍事攻撃に生成AIを活用



•AIが軍事サイバー・情報分析の中核ツールに

大量の情報（通信傍受、OSINT、衛星画像、SNS、諜報データなど）を統合分析するためにAIが活用されており、標的識別や状況認識（Situational Awareness）の速度を大幅に向上させている。これはサイバー領域での脅威インテリジェンス分析やSOCの高度化と同じ流れにある。

•AIモデルの利用制限が国家安全保障と衝突する可能性

AI企業が設定する「軍事用途制限」「監視用途制限」などの利用規約が、国家の軍事作戦やサイバー作戦と衝突するリスクが顕在化した。これは将来、政府機関がAIを安全保障用途で使う際の契約・規制の重要な論点になる。

•AI依存によるサプライチェーンリスクの顕在化

特定企業のAIモデルに依存すると、利用停止・契約変更・規約違反などで作戦能力が制約される可能性がある。軍事・政府機関にとってAIは新しい「デジタル・サプライチェーンリスク」となる。

•AIが意思決定速度を極端に加速させることによるリスク

AIが標的候補や攻撃判断を高速提示することで、意思決定プロセスが短縮され、人間による検証や法的レビューが追いつかない可能性が指摘されている。サイバー攻撃・軍事行動の「自動化リスク」として議論が進んでいる。

US forces used Claude in Iran strikes for intelligence, targeting even after Trump's ban

Trump had directed all federal agencies to immediately cease their use of artificial intelligence products developed by Anthropic, including the Claude model.

By Bojan Stojkovski

Military

Mar 01, 2026 06:28 PM EST



GET YOUR NEWS FROM
INTERESTING ENGINEERING



Pentagon relied on Anthropic AI to support Iran attack hours after Trump order.

Freepik

ベネズエラのインフラへのサイバー攻撃 (米国によるものとの報道)



2025/12/15

ベネズエラ国営石油にサイバー攻撃、システム停止か 米の仕業と批判

ロイター編集

2025年12月16日 午後 1:50 GMT+9・2025年12月16日更新

【15日 ロイター】 - ベネズエラ国営石油会社PDVSAは15日、サイバー攻撃を受けたと明らかにした。業務に支障は生じていないと説明したが、関係者によると、同社のシステムは依然として停止しており、石油貨物の引き渡しが中断している。

PDVSAとベネズエラ石油省はサイバー攻撃について、米国の仕業だと非難し「国内の勢力と結託した外国の勢力が行ったもので、エネルギーを開発するベネズエラの権利を破壊しようとしている」との見解を示した。「力と海賊行為」によってベネズエラの石油を支配しようとする米国の取り組みの一環だと主張した。

PDVSAは詳細には言及しなかったが、攻撃による影響は解消したと説明した。

しかしPDVSAの関係者は、同社が数日前にランサムウェアによる攻撃を検知し、問題を修復しようとして使用したウイルス対策ソフトが管理システム全体に影響を及ぼしたと説明。同社関係者の1人は「(貨物の) 引き渡しは行われておらず、全システムが停止している」と証言した。ベネズエラ産原油取引に関与する荷主の1人も、輸出市場向けの全ての積み荷指示が棚上げになっていることを認めた。

関係者によると、PDVSAは原油の生産、精製、国内での流通に支障が生じていないものの、15日に管理システムの再起動に失敗し、作業員は業務の記録を手作業で行わざるを得なくなった。さらに別の関係者2人は、PDVSAが管理部門と現場部門の職員に対して社内のシステムへの接続を切るよう命じ、間接雇用の作業員による施設への立ち入りを制限したと述べた。

2026/1/3

アメリカによるベネズエラ攻撃時に首都は停電し「BGP異常」が起こった



サイバーセキュリティ関連ニュースレターのLow Orbit Securityが、アメリカによるベネズエラ攻撃が行われた際に、ベネズエラでは停電が起き、BGP異常が起きたと報じています。

Radar #16: Week of 01/05/2026

<https://loworbitsecurity.com/radar/radar16/>

ドイツ機器メーカー Schumag AG がサイバー攻撃被害で倒産

✓ 2024年9月、ドイツの老舗精密機器メーカーSchumag AG（以下、S社）がランサムウェアグループ「8Base」によるサイバー攻撃を受けた。攻撃により社内システムが暗号化され、従業員情報や財務データなどの機密情報を窃取された。

✓ 工場の操業は一時停止し、同年9月25日に予定されていた株主総会も中止。以後、自主再建型の破産手続きを経て、2025年1月に新株主のもと事業再建。

時期	出来事・状況
2022/23年度末	売上：€51.2M／EBIT：-€2.9M／純損失：-€4.5M／自己資本：0％／現金残高：€0.5M
2024年9月22日	ランサムウェア「8Base」によるサイバー攻撃発生／生産停止・データ流出・社内混乱
2024年9月25日	定時株主総会が中止される
2024年10月8日	サイバー攻撃および売上急減についてのインサイダー情報を公表
2024年10月9日	アーヘン地裁に「自主再建型の破産手続」を申請
2024年10～12月	IT・生産環境の復旧作業
2024年12月	ほぼ全面的な生産再開を実現
2025年1月末	再建完了。「Schumag Precision GmbH」へ事業承継。事故発生時470名いた社員から、374名の雇用を維持
2025年2月1日	新会社が正式に事業を開始。ACCグループが筆頭株主として支援を継続

情報漏えい、株主総会延期、売上急減⇒不渡り⇒破産、システム復旧、雇用維持



直近のサイバーセキュリティ関連の政策動向

企業のセキュリティ評価（SCS評価制度）

サプライチェーン強化に向けたセキュリティ対策評価制度（SCS評価制度）の実現

SC対策強化

- 「対策状況は外部から判断が難しい」「複数の取引先から様々な対策を要求される」等の課題に対し、サプライチェーンにおける重要性を踏まえた上で満たすべき対策※1を提示しつつ、その状況を可視化する仕組み※2を構築（2026年3月27日に「制度構築方針」を公表）。
- 3段階の水準のうち、★3・★4について、2026年度末頃の制度開始を目指し、スキームオーナーであるIPAとともに、制度運営基盤の整備や利用促進等を進めていく。2026年度以降に★5の設計も進める。
- 制度開始5年後（2031年）までに2万件、10年後（2036年）までに5万件的★取得を目指す。

構築する評価制度			
成熟度の定義	★3	★4	★5 [検討中※3]
想定される脅威	広く認知された脆弱性等を悪用する一般的なサイバー攻撃	供給停止等によりサプライチェーンに大きな影響をもたらす企業への攻撃 機密情報等、情報漏えいにより大きな影響をもたらす資産への攻撃	未知の攻撃も含めた、高度なサイバー攻撃
対策の基本的な考え方	全てのサプライチェーン企業が最低限実施すべきセキュリティ対策： ・ 基本的な組織的対策とシステム防御策を中心に実施	サプライチェーン企業等が標準的に目指すべきセキュリティ対策： ・ 組織ガバナンス・取引先管理、システム防御・検知、インシデント対応等包括的な対策を実施	サプライチェーン企業等がさらに目指すべき高度な対策： ・ 国際規格等におけるリスクベースの考え方に基き、自組織に必要な改善工程を整備、システムに対しては現時点でのベストプラクティスの対策を実施
評価スキーム	専門家確認付き自己評価	第三者評価	第三者評価

※1 本制度では、サプライチェーンを構成する企業等のIT基盤が対象。
※2 発注時等に、必要なセキュリティ対応状況の可視化を目的としたもので、いわゆる「格付け」制度ではない。
※3 ISMS適合性評価制度、★3・★4との整合性も踏まえ、対策事項を今後検討

政府調達や重要インフラ事業者等での活用促進

取引先からの対策要請による活用促進

利害関係者への情報開示による対話の促進

サプライチェーン間の結び付きが強固・複雑な主要製造業（自動車、半導体等）、流通、金融業等において、優先的に本制度の利用を促進。

IoTセキュリティ適合性評価制度（JC-STAR）

- IoT製品のセキュリティ対策レベルを評価・可視化するJC-STARについて、製品型番ベースで1,500製品以上のIoT製品がラベル発行済み。ネットワークカメラ等の一部類型について、高度なセキュリティ基準（★3）も公開。
- セキュアなソフトウェアの開発・流通に向けた取組の具体化やサイバーインフラ事業者が果たすべき責務等の整理についても成果物を取りまとめ。
- これらの取組・制度について、G7をはじめとする関係国との調和を図るべく、議論も進展。

JC-STAR（ロゴ・ラベル、ラベル発行製品の例）



IoT製品及びソフトウェアに関する関係国との制度・取組調和に向けた成果文書

G7サイバーセキュリティWG
(WG議長声明、2025年6月) ※IoT

G7加盟国（政府）・産業界（IoTベンダー・エンドユーザー）に向けて、IoTセキュリティの確保のために技術的及び非技術的なサイバー脅威の考慮の必要性について提案。

JC-STARとPSTI法の相互承認
(2025年11月：署名、2026年1月：運用開始) ※IoT

英国の科学・イノベーション・技術省（DSIT）との間で、英国PSTI法が要求する技術基準（3要件）とJC-STAR★1のラベル取得に必要な技術基準の3要件が同等であるとみなすことに合意し、相互承認を開始。
* Product Security and Telecommunications Infrastructure Act

サイバーセキュリティのためのSBOMの共有ビジョンに関する国際ガイドンス (2025年9月) ※ソフトウェア

米国サイバーセキュリティ・インフラ安全庁（CISA）とともにSBOMの活用重要性を広く国際的に発信するとともに、SBOM運用上の国際共同ガイドンスを整備することを目的として作成。

セキュアなソフトウェア開発・流通に向けた取組

- 安全なソフトウェア開発のための事業者向けガイドンス案（中間整理）を拡充（2026年1月）
- サイバーインフラ事業者（※）が果たすべき責務等を整理したガイドライン策定（2026年3月）

（※）サイバーインフラ事業者とは、一定の社会インフラの機能としてソフトウェアの開発・供給・運用を行っている事業者を指す。

「セキュリティ対策」が「リスク低減のためのコスト」から「調達要件（ビジネスの参加条件）」に変容

取引先のセキュリティ対策は「調達基準」に

記事・株価を検索

日本経済新聞

朝刊・夕刊 LIVE Myニュース 日経会社情報 人事ウォッチ NIKKEI Prime

トップ 速報 ビジネス マーケット 経済 国際 オピニオン もっと見る #米中「新

キオクシア、供給網3000社のサイバー対策点検 脆弱企業は取引見直し【イブニングスクープ】

＜キオクシアの取り組み＞

- ・約3000社の取引先（部品納入、業務委託、クラウドサービス提供など）が対象。
- ・米SecurityScorecardを使い、**ウェブやサーバー設定、脆弱性の有無など約200項目を評価（右表）。**

＜評価と改善促進＞

- ・今秋からセキュリティー対応が弱い企業を抽出し、改善を求める。
- ・改善が中長期で見られなければ、**他の調達先に切り替える可能性あり。**

＜背景とリスク認識＞

- ・サプライチェーン上の1社の被害でも生産停止や情報漏洩が広がる恐れ。
- ・外部から見える脆弱性を放置する企業は攻撃者に狙われやすい。

＜契約・調達への影響＞

- ・新規契約先も診断対象。結果を調達部門と共有し、**取引継続の判断材料**にする。

分類	説明
1. ネットワークセキュリティ	インターネットに接続する仕組み全体の安全性を確認。不要な通信口（ポート）が開いていないか、危険な設定が残っていないかを点検する。
2. DNSの健全性	通信の宛先を正しく案内する「住所録」のような仕組みの設定状況を確認。誤設定や欠陥があると、偽サイトに誘導されたり、攻撃に悪用される可能性がある。
3. パッチ管理	ソフトウェアや機器の「修正プログラム（アップデート）」がきちんと適用されているかを確認。古いまま放置すると、既知の不具合や弱点を突かれて攻撃されやすい。
4. エンドポイントセキュリティ	社内のパソコンや端末が安全に利用されているかを確認。マルウェアに感染していないか、セキュリティソフトや更新が有効かをチェックする。
5. アプリケーションセキュリティ	Webサイトや業務システムが安全に作られているかを検証。外部からの不正入力（SQLインジェクション、クロスサイトスクリプトなど）に耐えられるかを確認する。
6. セキュリティの基本ルール	情報セキュリティの基本的な守り方が実施されているか。不要なサービスやアカウントを削除しているか、初期設定のまま運用していないかを確認する。
7. IPレピュテーション	自社のネット接続が「不正に使われていないか」を評価。スパムや攻撃の送信元として認識されていないかを調べる。
8. Webサイトの証明書（SSL/TLS）	サイトの通信が暗号化され、正しい証明書で保護されているかを確認。証明書の有効期限や暗号化の強度もチェック対象となる。
9. 情報漏えい	インターネットや闇サイトに自社の情報（社員のパスワードや内部資料）が漏れていないかを調査。過去の流出履歴も含めて確認する。
10. 攻撃対象の見え方	攻撃者の立場で見たときに、自社のどこが弱点になり得るかを点検。公開されているサーバやシステムに、不必要な露出がないかを評価する。



つながる社会の進展

サイバー脅威の
進化・深化

法規制・ガイドライン

ビジネスリスク増大
(ブランド毀損・生産停止・
品質低下等)

コンプライアンス違反リスク
調達要件充たせず失注

DX推進
OTのIT化

取引先の
サイバー攻撃発生による
ビジネス影響

取引先の
コンプライアンス違反による
調達リスク



製造DX時代のOTセキュリティの考え方



ITと工場とでは異なるビジネスゴール



情報セキュリティ
部門

情報・データを守る

Confidentiality(機密性)

Integrity (完全性)

Availability (可用性)



工場部門

生産活動・ビジネスを守る

Safety (安全性)

Quality (品質)

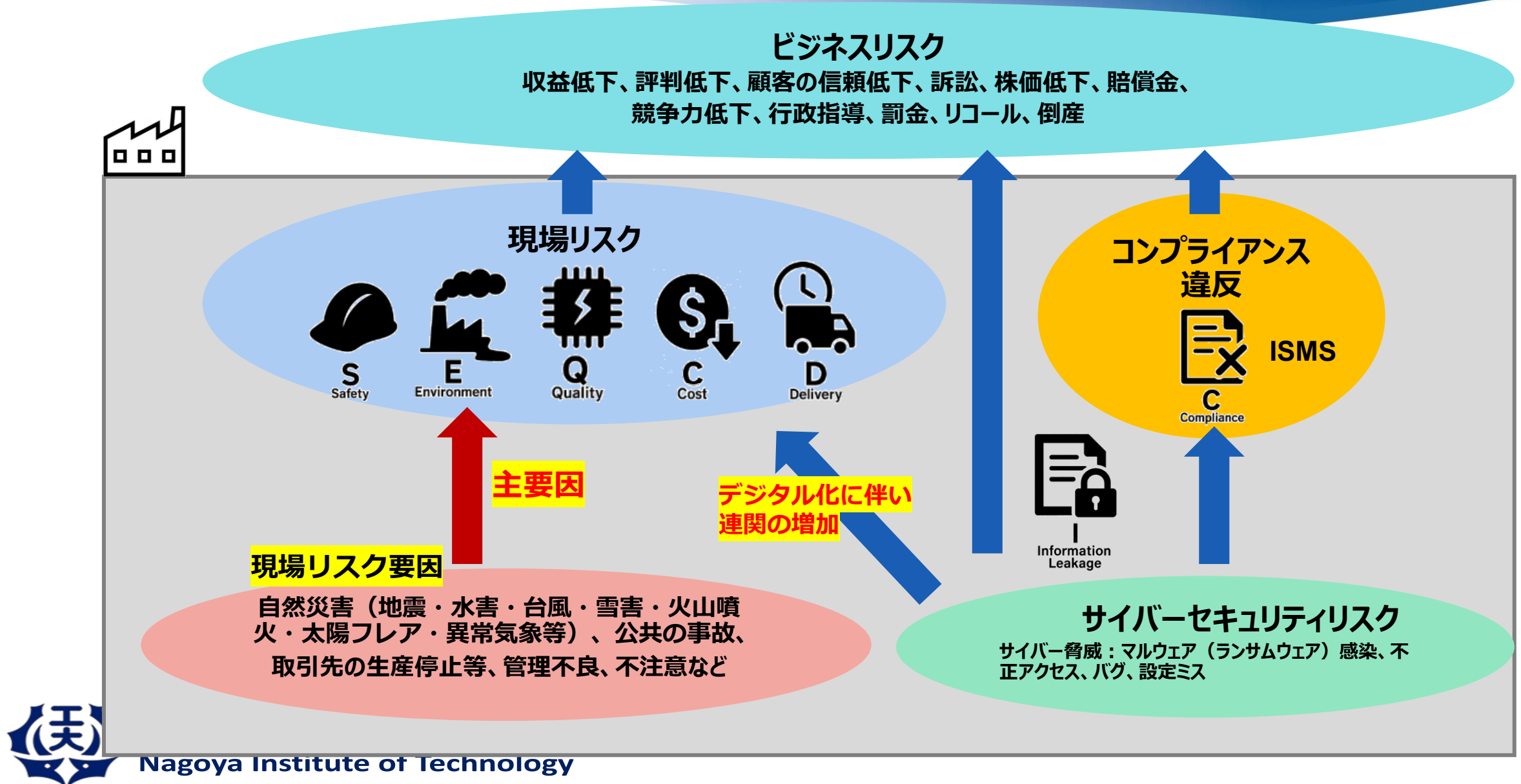
Environment (環境影響)

Cost (コスト)

Delivery (納期)

サイバーセキュリティは工場部門のビジネス目標達成のための手段

工場システムのビジネスリスクとサイバーセキュリティリスクの関係性



工場システムのビジネスリスクとサイバーセキュリティリスクの連鎖例

脅威の入口

- ・ネットワーク
- ・USBメモリ
- ・メンテナンスPC
- ・調達・導入

脅威の拡散

- ・マルウェア感染
- ・ネットワーク拡散
- ・複数端末感染
- ・端末乗っ取り

サイバーセキュリティ リスクの発現

- ・端末使用不可
- ・データ使用不可
- ・データ暗号化・破壊
- ・ネットワーク遅延/高負荷

現場リスク 発現

- ・機器不正動作による
人身事故(S)
- ・機器故障(S)
- ・火災(S)
- ・廃液流出(E)
- ・品質不良(Q)
- ・生産停止(C)
- ・出荷停止(D)
- ・重要情報漏洩(I)

ビジネスリスクへ 連鎖的に発展

- ・労災補償
- ・高額な復旧費用
- ・行政指導・罰金
- ・損害賠償
- ・リコール
- ・売上損失
- ・納期遅延
- ・株価低下
- ・競争力低下
- ・経営責任
- ・評判低下
- ・売上低下
- ・シェア低下
- ・取引先喪失
- ・資金繰り悪化
- ・破産・倒産

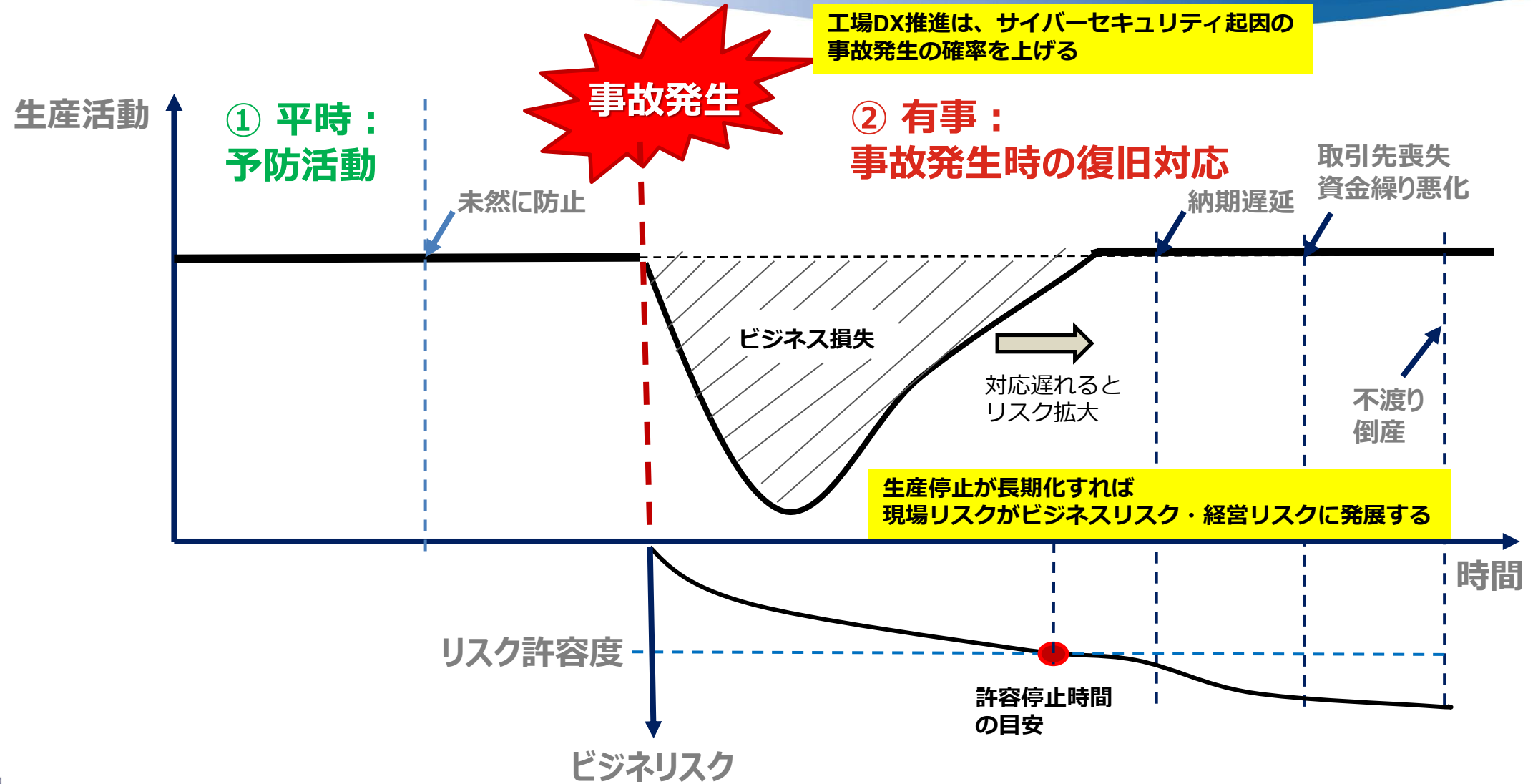
サイバーセキュリティリスクは、多様なビジネスリスクのひとつ&原因事象である



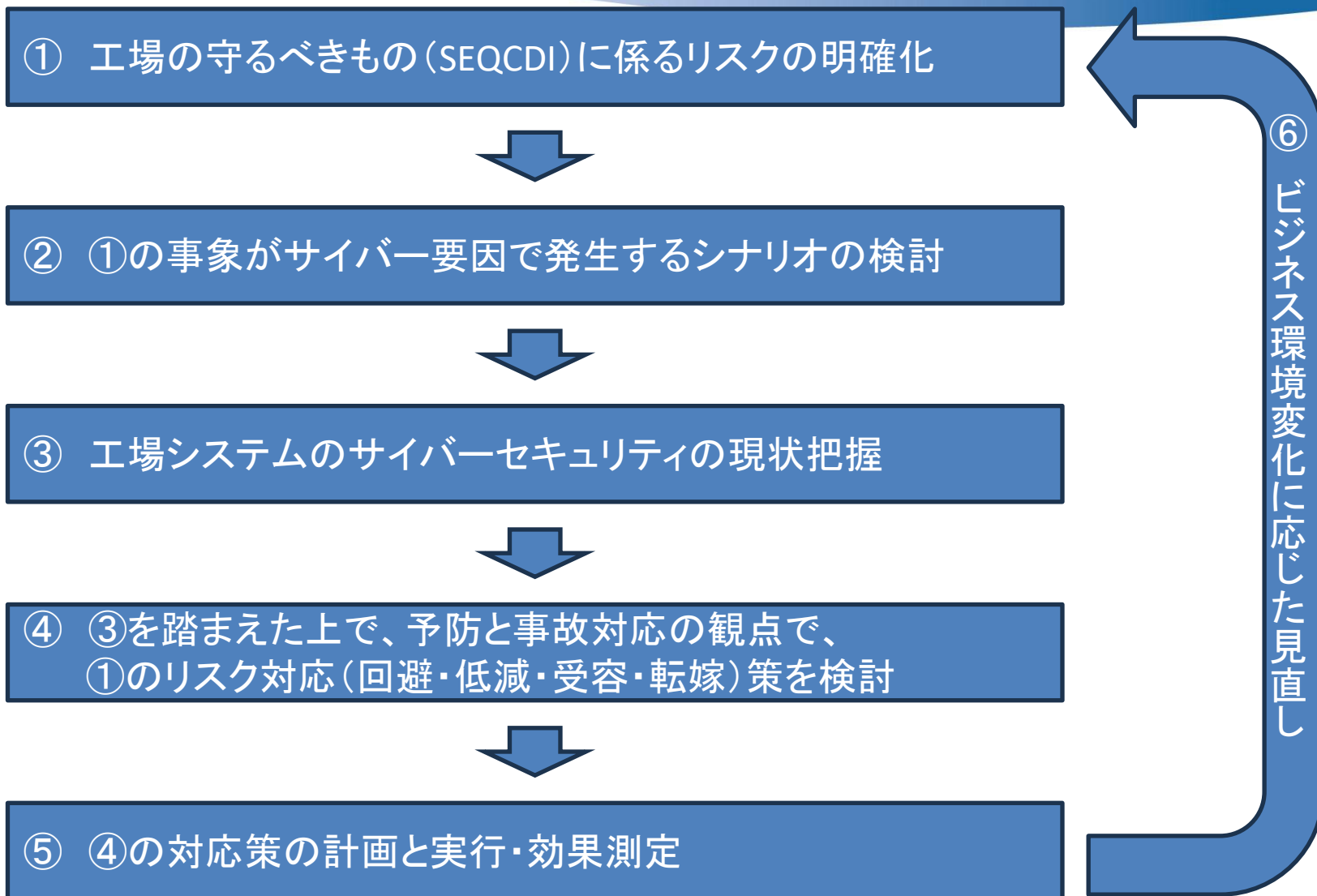
リスク管理（リスク対応：回避・低減・転嫁・受容）はビジネスリスクを中心に考える



レジリエントな工場は“予防と事故対応”の観点で考える



工場システムのサイバーセキュリティ対策の原則的な進め方



経済産業省 工場セキュリティガイドライン概要

✓ 2022年1月6日、経済産業省は、産業サイバーセキュリティ研究会WG1（制度・技術・標準化）のサブWGとして工場SWGを設置。

ガイドラインの取りまとめ着手。

✓ DX進展等の工場環境変化により高まるセキュリティリスクへの対策について、**工場のステークホルダー間の相互信頼の土台となる考え方を整理**

✓ 2022年11月16日、パブリックコメント版を反映したガイドラインVer1.0が公開。



工場システムにおけるサイバー・フィジカル・セキュリティ対策ガイドライン ～全体概要～

ガイドラインの背景・目的

- 工場のIoT化によるネットワーク接続機会の増加に伴いサイバー攻撃リスクが増加。また、ネットワークの接続に乏しい工場であっても不正侵入者等による攻撃の可能性あり。
- 意図的な攻撃の場合もあれば、たまたま攻撃される場合もある。
→ **いかなる工場でもサイバー攻撃のリスクあり。**
- 本ガイドは業界団体や個社が自ら対策を企画・実行するに当たり、参照すべき考え方やステップを示した「手引き」。
- **各業界・業種が自ら工場のセキュリティ対策を立案・実行することで、工場のセキュリティの底上げを図ることが目的。**

想定する読者の方

- ITシステム部門
- 生産関係部門（生産技術部門、生産管理部門、工作部門等）
- 戦略マネジメント部門（経営企画等）
- 監査部門
- 機器システム提供ベンダ、機器メーカー（サプライチェーンを構成する調達先を含む）

※想定読者が経営層（CTO、CIO、CISO）をはじめとした意思決定層と適切なコミュニケーションを行うことが重要。

対策に取り組む効果

- 工場のBC/ SQDC[※]の価値がサイバー攻撃により毀損されることを防止。
- セキュリティが担保されることでIoT化や自動化が進み、多くの工場から新たな付加価値が生み出されていくことを期待。

※ 安全確保(S: Safety)、事業/生産継続(BC: Business Continuity)、品質確保(Q: Quality)、納期遵守・遅延防止(D: Delivery)、コスト低減(C: Cost)

セキュリティ対策企画・導入の進め方

ステップ 1

内外要件（経営層の取組や法令等）や業務、保護対象等の整理

- ステップ1-1 セキュリティ対策検討・企画に必要な要件の整理
(1)経営目標等の整理
(2)外部要件の整理
(3)内部要件/状況の把握
- ステップ1-2 業務の整理
- ステップ1-3 業務の重要度の設定
- ステップ1-4 保護対象の整理
- ステップ1-5 保護対象の重要度の設定
- ステップ1-6 ゾーンの整理とゾーンと業務、保護対象の結びつけ
- ステップ1-7 ゾーンと、セキュリティ脅威の影響の整理

ステップ 2

セキュリティ対策の立案

- ステップ2-1 セキュリティ対策方針の策定
- ステップ2-2 想定脅威に対するセキュリティ対策の対応づけ
(1)システム構成面での対策
①ネットワークにおけるセキュリティ対策
②機器におけるセキュリティ対策
③業務プログラム・利用サービスにおけるセキュリティ対策
(2)物理面での対策
①建屋にかかわる対策
②電源/電気設備にかかわる対策
③環境(空調など)にかかわる対策
④水道設備にかかわる対策
⑤機器にかかわる対策
⑥物理アクセス制御にかかわる対策

ステップ 3

セキュリティ対策の実行、及び計画・対策・運用体制の不断の見直し（PDCAサイクルの実施）

- ライフサイクルでの対策
サプライチェーンを考慮した対策
(1)ライフサイクルでの対策
①運用・管理面のセキュリティ対策
A)サイバー攻撃の早期認識と対処（OODAプロセス）
B)セキュリティ対策管理(ID/PW管理、機器の設定変更など)
C)情報共有
②維持・改善面のセキュリティ対策
・セキュリティ対策状況と効果の確認・評価、環境変化に関する情報収集、対策の見直し・更新
・組織・人材のスキル向上（教育、模擬訓練等）
(2)サプライチェーン対策
・取引先や調達先に対するセキュリティ対策の要請、対策状況の確認

事業や環境、技術の変化に応じて各ステップについて不断の見直しを行いながらステップのサイクルを回す

Web診断で先ずは簡易的に現状把握

経産省工場セキュリティガイドライン準拠チェックリスト活用

セキュリティ対策の現状把握のためのヒアリングシート

カテゴリ	サブ項目	確認項目 V1.0	現状評価	ヒアリング回答
組織	ガバナンス体制	1-1 工場システムのセキュリティの必要性について、決裁者（工場長、カンパニー長等）又は経営層が意思を持っており、十分な資源・人材配分などの協力を得られる。	2：部分的に実施している	認識はあるが、予算・人員の確保は難しい（途上）
	ガバナンス体制	1-2 工場関係者（経営層・従業員）がセキュリティに関する意識を高め、適切な行動をとっている。	2：部分的に実施している	IT体制を検討中。現時点では、何かあればCSIRTが対応。
	ガバナンス体制	1-3 工場関係者（経営層・従業員）がセキュリティに関する意識を高め、適切な行動をとっている。	2：部分的に実施している	（同上）
	ガバナンス体制	1-4 工場関係者（経営層・従業員）がセキュリティに関する意識を高め、適切な行動をとっている。	2：部分的に実施している	IT体制を検討中。現時点では、何かあればCSIRTが対応。
	現場教育	1-5 工場関係者（経営層・従業員）がセキュリティに関する意識を高め、適切な行動をとっている。	2：部分的に実施している	IT体制を検討中。現時点では、何かあればCSIRTが対応。
	定期評価	2-1 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	IT体制を検討中。現時点では、何かあればCSIRTが対応。
運用	ルール策定・管理	2-2 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	一部サーバのみ、遠隔バックアップ、冗長構成実施（1-4C同し）
	ルール策定・管理	2-3 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	工場セキュリティの対応を伴成中
	インシデント対応	2-4 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	FW適用部門内で内部ルール化して運用。
	インシデント対応	2-5 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	資産管理	2-6 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	資産管理	2-7 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
技術	定期評価	2-8 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	ルール策定・管理	2-9 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	ルール策定・管理	2-10 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	ルール策定・管理	2-11 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	ルール策定・管理	2-12 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	インシデント対応	2-13 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
サプライチェーン	脆弱性管理	3-1 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	脆弱性管理	3-2 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	脆弱性管理	3-3 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	脆弱性管理	3-4 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	脆弱性管理	3-5 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	
	脆弱性管理	3-6 工場システムにおけるセキュリティの脆弱性や脆弱性に関するリスクを評価している。	2：部分的に実施している	

組織的対策

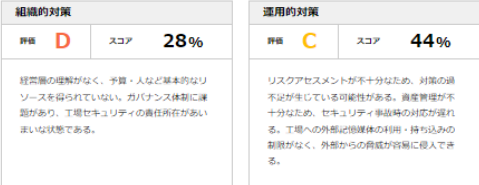
運用的対策

技術的対策

サプライチェーン管理

診断結果

グラフはOTセキュリティ対策のスコアを表示しています。
グラフの横が大きいほど大きいほど、OTセキュリティ対策が行われていることを示します。



- ☐ 自組織に当てはまらない
- ☐ 実施していない
- ☐ 部分的に実施している
- ☐ 実施している
- ☐ 実施し、管理手順を文書化・自動化している
- ☐ 実施し、外部環境変化に随時対応している

分析結果シートの見方

スコア	0～100	チェックシートの個別項目と回答(0-4)に重みづけをして、セキュリティ対策の状況をスコア化。全ての項目が「一部実施」の場合に約40%、「実施している」だと約60%となるように調整している。
評価	スコア	解説
A	80～	ほとんどの必要な対策が実施され、手順が文書化されている。リスクを十分低減できており、継続的な改善がなされている。
B	60～79	ほとんどの必要な対策が実施されているが、手順が文書化できていない。リスクを低減できているが、継続的な改善に課題がある。
C	40～59	ほとんどの必要な対策の実施が不十分。リスクが低減されておらず、セキュリティ侵害時の被害が大きいと想定される。
D	0～39	ほとんどの必要な対策が未実施。リスクが認識されておらず、セキュリティ侵害時の被害が大きいと想定される。

注意事項：この診断結果は、設問に対する回答をもとに作成した簡易的なものであるため、**回答者の主観により異なる結果が出る、実態と乖離があるなどの可能性**があります。より精度の高い診断を行うために、現地ヒアリング・通信モニタリング調査の実施をお勧めします。



チェックリストWeb診断ツール：オープンソース公開

Human-Centered Design and User Experience, Vol. 114, 2023, 331–337

<https://doi.org/10.54941/ahfe1004251>



Analysis of Cybersecurity Risk for Factory Systems

Hiroshi Sasaki^{1,2}, Kenji Watanabe¹, and Ichiro Koshijima²

¹Nagoya Institute of Technology, Gokiso-cho, Showa, Nagoya, Japan

²Manufacturing and Innovation DX Laboratory, Nagoya Institute of Technology, Gokiso-cho, Showa, Nagoya, Japan

ABSTRACT

As the digitization of factory systems progresses and the number of digital connections between factories increases, cybersecurity risks throughout the supply chain also increase. In fact, there have been many cases where factories have stopped due to damage from ransomware. For large enterprises, it is possible to secure the budget and personnel for cybersecurity, including outsourcing. However, almost all small and mediums enterprises (SMEs) are facing with the difficulties to secure them. In this paper, we used a web diagnostic tool for simple risk assessment of factory systems using the checklist for understanding the rough risk posture in the appendix of “The Cyber/Physical Security Framework for Factory Systems” formulated by the Ministry of Economy, Trade and Industry in November 2022. After analysing the survey results from 225 factory sites and interviews from some respondents, we elicited the common challenges for promoting security measures for the factory systems.

Keywords: Operational technology (OT) security, Risk analysis of cybersecurity for factory system, Risk assessment tool for factory system

https://openaccess.cms-conferences.org/publications/book/978-1-958651-90-2/article/978-1-958651-90-2_36



-Japanese

<https://github.com/OTSec-Hiroshi-Sasaki/ja-ot-security-simple-assessment>

- English

<https://github.com/OTSec-Hiroshi-Sasaki/en-ot-security-simple-assessment>

自身のPCローカルでチェックリストをもとにした診断が可能



Nagoya Institute of Technology

工場サイバーセキュリティの進め方の事例

初回工場・
対象システム選定

簡易Web診断



診断結果

評価
C/D

プロジェクト・予算化

経営層説明・
現場巻込調整

現状把握 ①・②・③

OTリスクワークショップ

OT リスクワークシート			
Work1. サイバーセキュリティリスク		Work2. 起こってほしくない事象の列挙・優先順位付け	
Category	リスク要因	事象	優先順位
People		Safety	
Process		Environment	
Technology		Quality	
FA/SCM		Cost	
		Delivery	
		Others	

Work3. サイバーセキュリティリスクシナリオ

シナリオ	発生可能性	被害の大きさ	リスクレベル
1. 最近よくある被害	高	中	高
2. 過去に発生した被害	中	高	高
3. 想定外の被害	低	高	高

現場ネットワーク調査



現場リスクと
サイバーセキュリティ
リスクの洗い出し
と紐づけ

対策検討・計画 ④

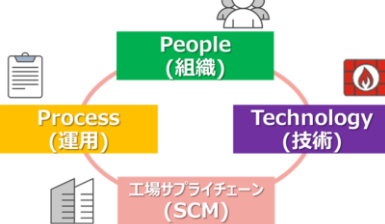
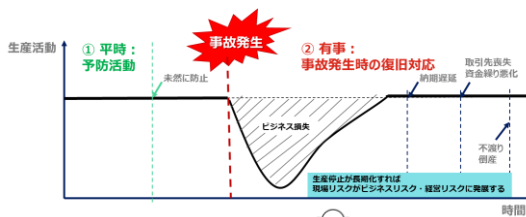
検討体制構築

事務局

組織・運用 WG

技術・SCM WG

予防と事故対応の観点で
リスク対応の検討



実装 ⑤

組織・運用改善活動
技術予算取り→導入・運用



カテゴリ	導入・運用
組織	
運用	
技術	
SCM	

チェックリスト再評価

経営層報告会

評価
B

継続的見直し ⑥

ビジネス環境変化に応じた
見直し



評価
A

他の拠点・対象工場に
同じ「進め方」で横展開



工場セキュリティ改善活動の進め方 – WG活動

全体推進+2つのワーキンググループによる定例会議を通じて、現場のリスク管理にサイバーセキュリティを組み込む。

全体推進・ガバナンスWG

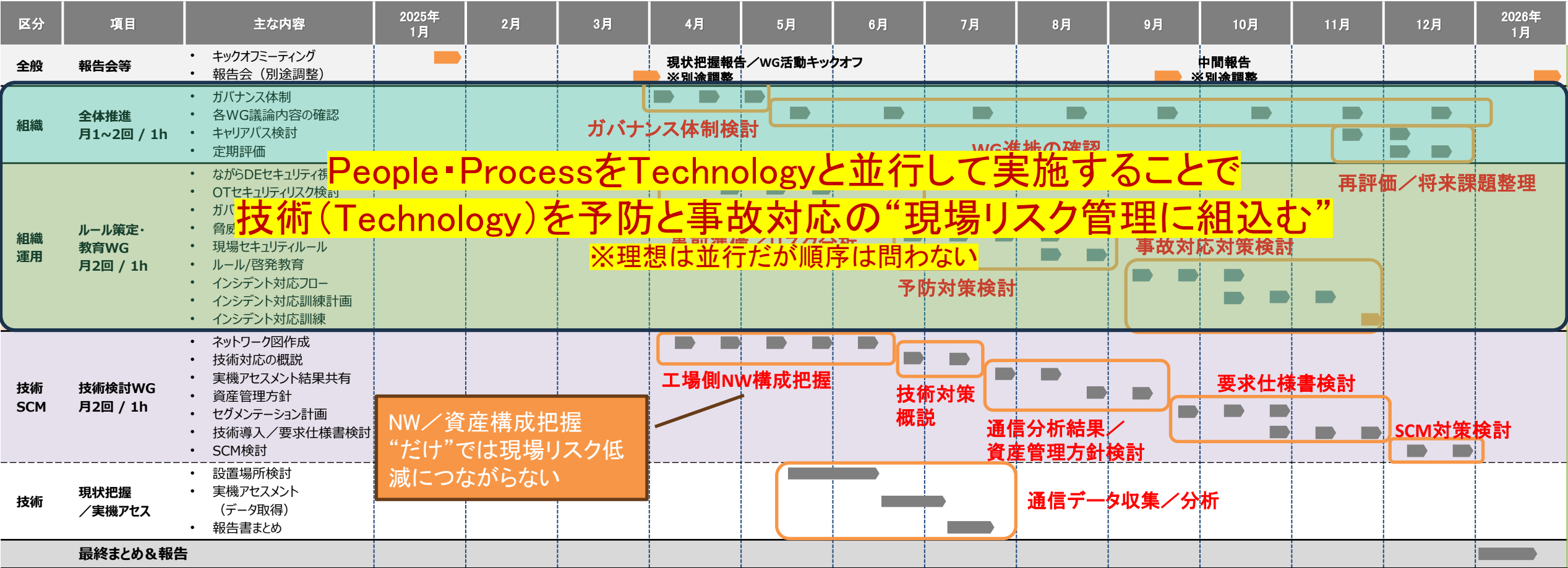
- ガバナンス部門としての各WG検討内容／進捗の確認
- 「組織的対策の一部(ガバナンス体制等)」の検討

ルール策定・教育WG

- 「組織的対策」「運用的対策」の検討の主体

技術検討WG

- 「技術的対策」「工場システムサプライチェーン管理対策」の検討の主体



OTリスクワークショップ^oサイバーセキュリティ対策を現場の自分事にする

Work1. サイバーセキュリティリスク

Category	リスク要因
組織・人	
運用	
技術	
工場 サプライ チェーン	

IT/セキュリティ部門主導
経産省ガイドラインチェックリスト

Work2. 起こってほしくない事象の列挙・優先順位付け

工場目標	起こってほしくない事象	Priority
Safety		1
Environment		2
Quality		3
Cost		4
Delivery		5
Others		6

OT部門主導
サイバー関係ない現場リスク

Work3. サイバーセキュリティリスクシナリオ

#	起こってほしくない事象	リスクシナリオ（脅威シナリオではないことに注意：ビジネスインパクトを記載すること）
1		
2		
3		

IT/セキュリティ部門とOT部門の共同検討
サイバーリスクと現場リスクの紐づけ

OT リスクワークショップ^o IT/OT部門・経営層の共通認識醸成

Work1. サイバーセキュリティリスク

Category	リスク要因
組織・人	・OTセキュリティの責任はビジネスマネージャーに割り当てられているが、全体的なガバナンスの準備が不十分であり、形だけのものである。 ・企業全体でITセキュリティのトレーニングは提供されているが、OTセキュリティのトレーニングは提供されておらず不十分である。
運用	・工場システムのリスク評価が実施されていない。 ・サイバーセキュリティのインシデント対応手順がない。 ・OTリスクベースのルールが決められていない。 ・USBメモリデバイスの取り扱いルールが不十分である。 ・工場の資産管理が不十分である。 ・重要な工場資産のバックアップ準備がない。 ・重要な工場資産のバックアップ回復訓練がない。
技術	・古いOS（例：Windows XP、7など）の端末のセキュリティ対策がない。 ・ITシステムと工場システムの間に境界防御がない。 ・セグメンテーションがないフラットなネットワーク構造である。 ・インシデント分析のためのセキュリティログがない。
工場サプライチェーン	・工場資産のシステムインテグレーターやベンダーとの間でインシデント対応や資産の脆弱性に関するセキュリティ協定がない。 ・セキュリティ調達プロセスおよび受入検査がない。

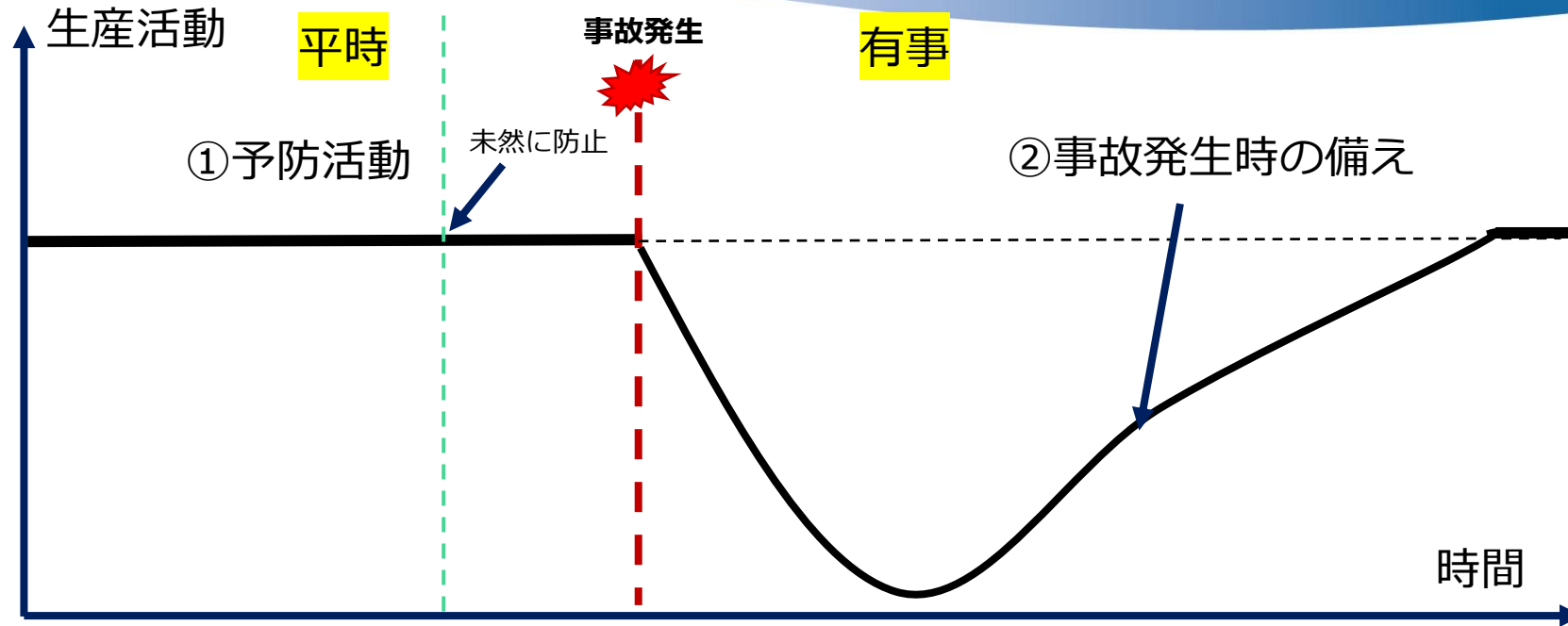
Work2. 起こってほしくない事象の列挙・優先順位付け

工場目標	起こってほしくない事象	Priority
Safety	・爆発 / 火災 / 物理的損害 ・人的損害 ・工場資産の故障	1
Environment	・有害ガスの大気への漏洩 ・有害液体の河川や海への漏洩	2
Quality	・製品の欠陥による製品のリコール ・品質データの喪失によるトレーサビリティの不足	3
Cost	・生産停止による損失 ・中間製品や原材料の廃棄による損失 ・オペレーターの給与の損失	4
Delivery	・収益機会の損失 ・納期遅延による顧客の信頼の喪失	5
Others	・SNSへの機密情報のアップロードによる評判の損失 ・コンプライアンス違反	6

Work3. サイバーセキュリティリスクシナリオ

#	起こってほしくない事象	リスクシナリオ（脅威シナリオではないことに注意：ビジネスインパクトを記載すること）
1	爆発 / 火災 / 物理的損害	・ USBメモリードライブの使用管理が不十分 なため、化学工場の 古いOSベースの端末 がマルウェアに感染し、 悪意を持って操作 される。その結果、工場に爆発や火災などの深刻な損害が生じる。
2	製品の欠陥による製品のリコール	・ ITシステムと工場システムの間に 境界防御がない ため、マルウェアがITシステムから工場システムに広がる。これにより、 レシピデータの操作 により欠陥のある化学製品が生産される。
3	生産停止による損失	・ セグメンテーションがなく、フラットなネットワーク構造 のため、一度マルウェアが工場システム内の端末に感染すると、工場全体に広がる。 資産管理が不十分でセキュリティログもない ため、 回復に非常に時間がかかり 、長期的な生産停止が発生する。

主なリスク要因とセキュリティ事故予防・対応の関係性



「工場リスク認識が低い」
「IT/工場の境界防御が不十分」

脅威の発生確率が増加

* デジタル化の進展によって
インシデント発生リスクが
高まる傾向

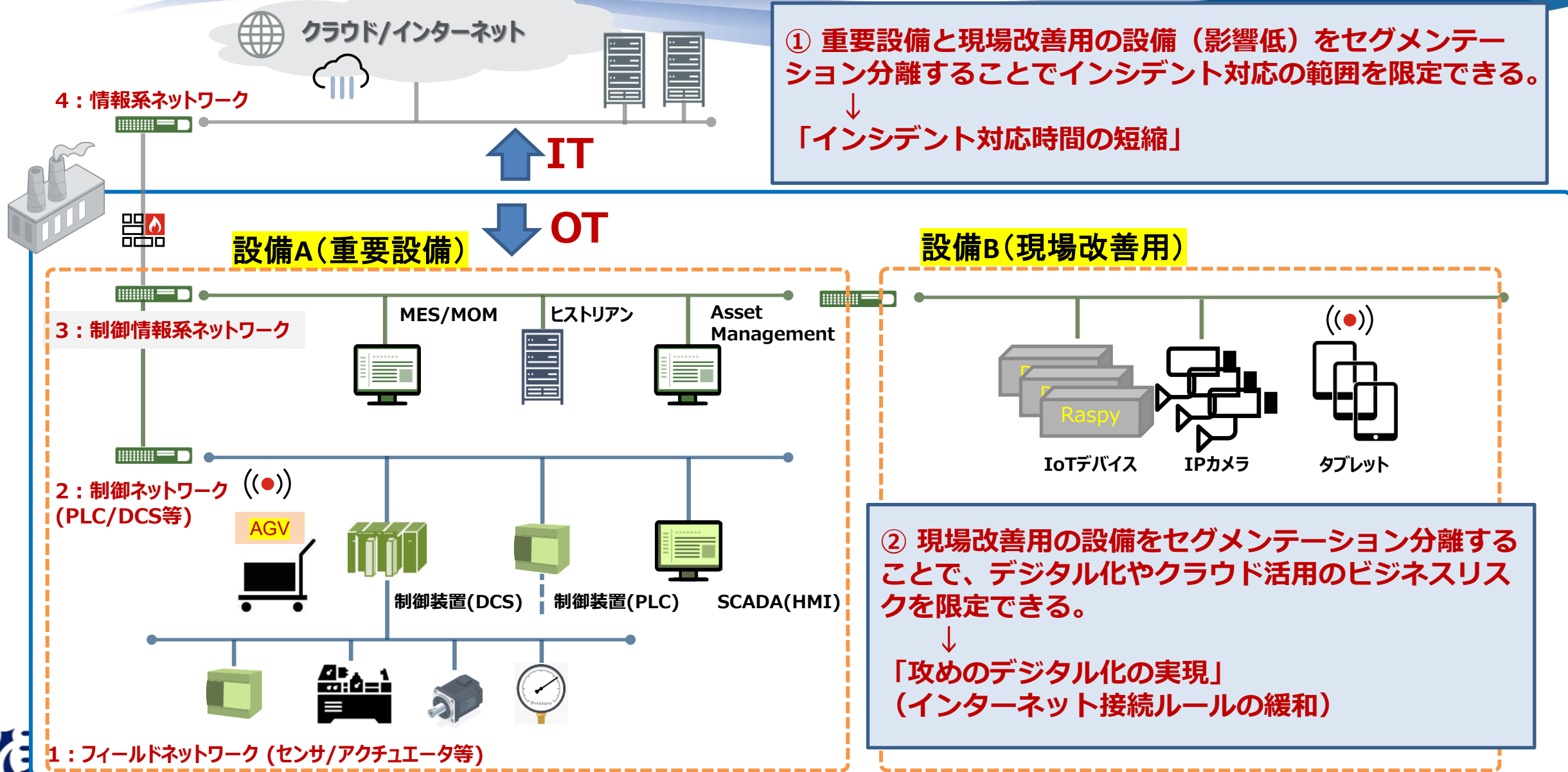
「資産管理が不十分」
「工場ネットワークのセグメンテーション分離なし」

事故対応の時間増加

* 資産管理が不十分だと事故対応時の特定が困難。
適切な境界防護・セグメンテーションがないと
脅威(マルウェア等)が拡散しやすい



スマート工場のカギ（ネットワークセグメンテーション）



工場セキュリティ対策は「現場のリスク管理」の一部である

セキュリティの脅威と本当に起きて欲しくないこと(=ビジネスリスク)を紐づける！

製造業で起きて欲しくないこと(=ビジネスリスク)



Safety



Quality



Environment



Cost



Delivery

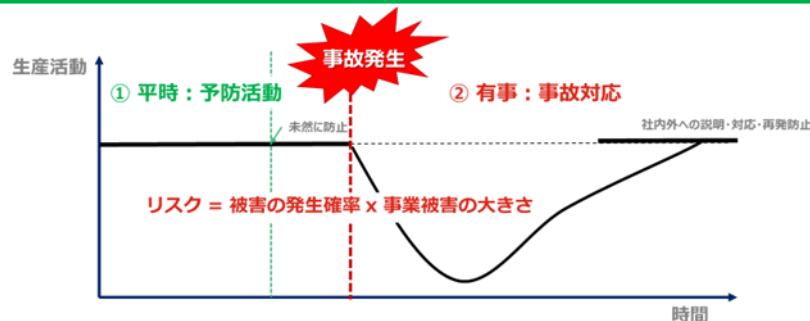
1. 生産活動が継続できなくなること
2. 従業員を始めとする人に対して安心・安全が損なわれること
3. その他 固有のビジネスリスクが発生し影響を及ぼすこと

<STEP 1>

自身の製造現場で本当に起きて欲しくないこと検討！

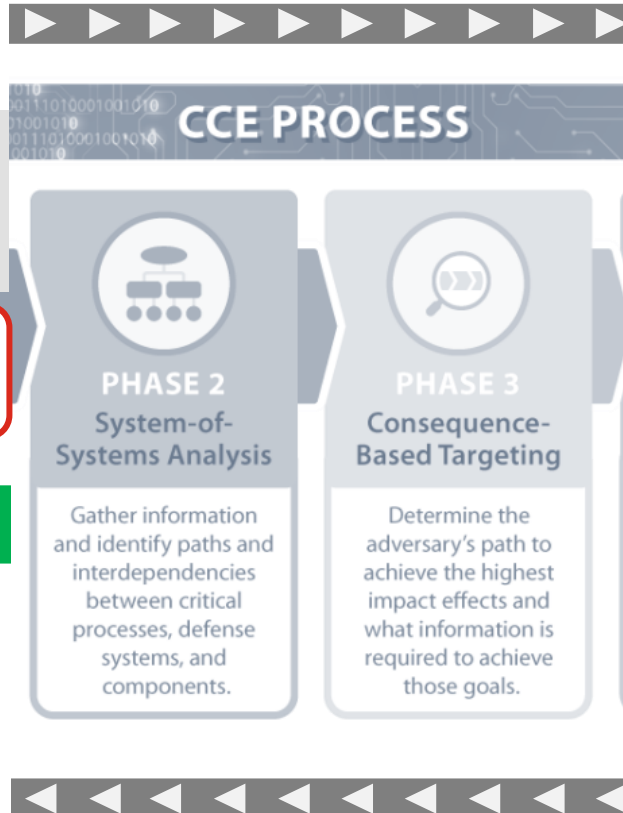
Prioritization

予防と事故対応の観点で対策実施



<STEP 4>

それぞれの対策方針が①予防、②事故対応の観点で効果があるかを整理しリスク低減のための対策を実施



サイバー要因 脅威の入口



外部ネットワーク経由のサイバー攻撃



USBメモリ経由のサイバー攻撃



外部からの持ち込みデバイス



不正な動作をするコードを調達時に埋込み

<STEP 2>

ビジネスリスクが対象システムにおいてサイバー要因でおきる可能性があるかどうかチェック！

Protections

優先順位付け、サイバーBCPの建付け



Planning

Recovery



Management



Operation



Risk

Resilience



Procedure

BCP(事業継続計画)とは、災害などの緊急事態が発生したときに、企業が損害を最小限に抑え、事業の継続や復旧を図るための計画

<STEP 3>

現状把握を行った上でビジネスリスク要因を組織・運用・技術・SCM毎に分析し想定シナリオと対策方針を検討

工場システムのリスク低減の考え方

脅威の入口

- ・ネットワーク
- ・USBメモリ
- ・メンテナンスPC
- ・調達・導入

脅威の拡散

- ・マルウェア感染
- ・ネットワーク拡散
- ・複数端末感染
- ・端末乗っ取り

サイバーセキュリティ リスクの発現

- ・端末使用不可
- ・データ使用不可
- ・データ暗号化・破壊
- ・ネットワーク遅延/高負荷

サイバーセキュリティに関する対策

経産省ガイドライン
NIST CSF
IEC62443

...

現場リスク 発現

- ・機器不正動作による
人身事故(S)
 - ・機器故障(S)
 - ・火災(S)
 - ・廃液流出(E)
 - ・品質不良(Q)
 - ・生産停止(P)
 - ・出荷停止(D)
 - ・重要情報漏洩(I)
- サイバー要因を
踏まえた
安全対策
事故対応計画
手動運用

...

ビジネスリスクへ 連鎖的に発展

- ・労災補償
 - ・高額な復旧費用
 - ・行政指導・罰金
 - ・損害賠償
 - ・リコール
 - ・売上損失
 - ・納期遅延
 - ・株価低下
 - ・競争力低下
 - ・経営責任
 - ・評判低下
 - ・売上低下
 - ・シェア低下
 - ・取引先喪失
 - ・資金繰り悪化
 - ・破産・倒産
- ビジネス継続計画
サイバー保険
顧客・株主説明
サプライチェーン対応
SNS対策

...

工場システムのリスク低減は、サイバーセキュリティリスク、
現場リスク、ビジネスリスクの“多層防御”で考える



経済産業省の工場セキュリティガイドラインを活用して 「説明責任」と「実効性」の両方を実現

説明責任

実効性

- ・コンプライアンス順守
- ・取引先への説明（共通言語）
- ・ガイドライン適合性



但し、形骸化しやすいことに注意

- ・設定・運用で大きな差がでる
- ・リスク評価が重要
- ・ビジネスリスク・現場リスク考慮



サイバー対策だけでは不十分

“経済産業省のガイドラインに
適合しています！”

“経済産業省のガイドラインを参考に
自社のリスク応じた対策に
落とし込んでいます！”



まとめ

近年のサイバーセキュリティリスクは、**情報セキュリティリスク**から、**ビジネスリスク、サプライチェーンリスク**へと波及している

DXを安心・安全に進めるためには、
“サイバーセキュリティ”を事業継続計画（BCP）に組込むことが鍵

サイバーセキュリティ対策は、予防と事故対応の観点で
リスク対応の“多層防御”で考えるべし

IT部門のみが主導するサイバーセキュリティ対策はうまくいかない
共通言語の力で、経営層・現場を巻き込むことから始めよう！

